

ACTIVIDAD 04

Una página demasiado convincente

Simulación controlada de ingeniería social con Social-Engineer Toolkit

Institución	Universidad Politécnica de San Luis Potosí
Materia	CNO IV - Seguridad Informática
Parcial	Parcial I - Fundamentos de Ciberseguridad
Alumno	Bruno Luna
Docente	Mtro. Servando López Contreras
Fecha	1 de septiembre de 2026

Entorno de laboratorio controlado - localhost - datos ficticios

Tabla de índice

1. Objetivo de la actividad	3
2. Descripción del escenario	3
3. Configuración del laboratorio	4
4. Evidencias y descripción del funcionamiento	5
5. Explicación del flujo de captura de información	13
6. Indicadores de phishing	14
7. Controles de seguridad propuestos	15
8. Conclusión	16
9. Referencias	16

Nota: la práctica se realizó exclusivamente en la máquina Kali Linux y se mantuvo en localhost, sin publicar servicios hacia Internet ni involucrar cuentas, dominios o credenciales reales.

1. Objetivo de la actividad

Implementar y analizar, dentro de un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET), utilizando un portal web ficticio para observar el proceso de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

De forma específica, la práctica buscó configurar SET, preparar un escenario de correo local, implementar un portal ficticio con el módulo Credential Harvester, analizar el recorrido de los datos enviados por un formulario y proponer medidas de protección frente a campañas de phishing.

2. Descripción del escenario

El escenario representa una campaña de ingeniería social en la que un usuario recibe un mensaje de seguridad con carácter urgente y posteriormente accede a un portal aparentemente institucional. Para evitar cualquier afectación a terceros, la simulación fue construida desde cero con nombres, direcciones y credenciales ficticias.

El correo se generó con SET y fue enviado únicamente a un buzón local de pruebas proporcionado por Mailpit. El portal de autenticación fue diseñado específicamente para la actividad bajo el nombre NEXORA y contenía los campos de usuario y contraseña, un botón de ingreso y el mensaje "Su sesión ha expirado. Inicie sesión nuevamente para continuar."

La práctica no utilizó páginas reales, servicios externos, suplantación DNS, payloads, código malicioso ni credenciales personales. El objetivo fue comprender el flujo técnico de una técnica de captura de información, no realizar un ataque contra usuarios reales.

3. Configuración del laboratorio

Todo el ejercicio se ejecutó dentro de una máquina virtual Kali Linux. Los servicios de correo y web se enlazaron a 127.0.0.1 para mantener el tráfico en la interfaz de loopback. Esta decisión permitió reproducir el flujo de una campaña de phishing sin exponer el servidor a la red pública.

Elemento	Configuración
Sistema	Kali Linux en máquina virtual
Herramienta principal	Social-Engineer Toolkit (SET)
Servidor SMTP de pruebas	Mailpit - 127.0.0.1:1025
Interfaz web de Mailpit	http://127.0.0.1:8025/
Servidor del Credential Harvester	http://127.0.0.1/ - puerto 80
Portal	NEXORA // Access Gateway - sitio ficticio
Datos de prueba	lab_user_01 / contraseña ficticia de laboratorio
Persistencia de resultados	Reporte XML generado por SET en /root/.set/reports/

3.1 Comandos y rutas principales

```
mailpit --listen 127.0.0.1:8025 --smtp 127.0.0.1:1025
sudo setoolkit
Mass Mailer Attack > E-Mail Attack Single Email Address > Pre-Defined Template >
Urgent Security Updates
Website Attack Vectors > Credential Harvester Attack Method > Custom Import
```

En el Mass Mailer se configuró el buzón de laboratorio lab_user@local.test, el remitente ficticio security@portal.local.test, el servidor SMTP 127.0.0.1 y el puerto 1025. Para Credential Harvester, la dirección de POST back se estableció en 127.0.0.1 y el sitio importado correspondió al portal NEXORA creado para el laboratorio.

4. Evidencias y descripción del funcionamiento

Las siguientes evidencias muestran el procedimiento en el mismo orden en que se realizó. Cada captura corresponde a una etapa verificable del laboratorio: preparación del SMTP local, generación del mensaje, recepción del correo, configuración del Credential Harvester, publicación local del portal ficticio, captura del POST y conservación del registro final.

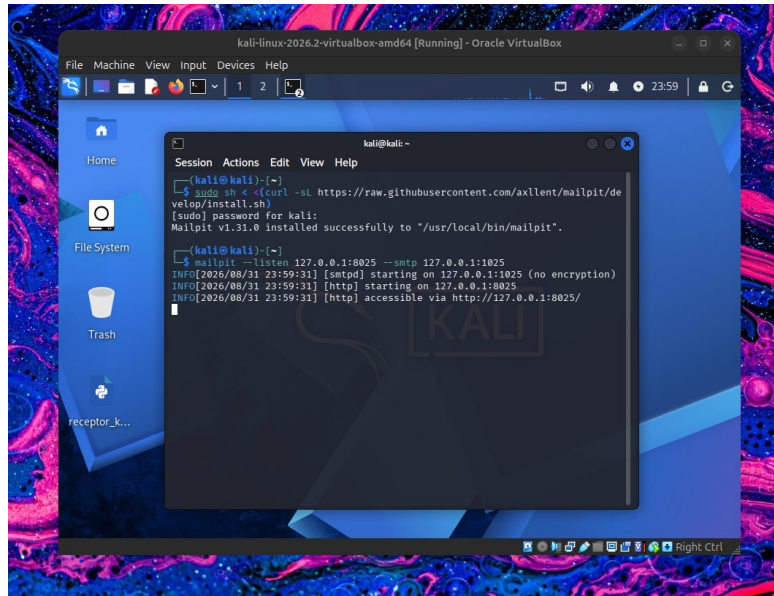


Figura 1. Inicialización de Mailpit.

Mailpit se ejecutó localmente con la interfaz web en 127.0.0.1:8025 y el servicio SMTP en 127.0.0.1:1025.

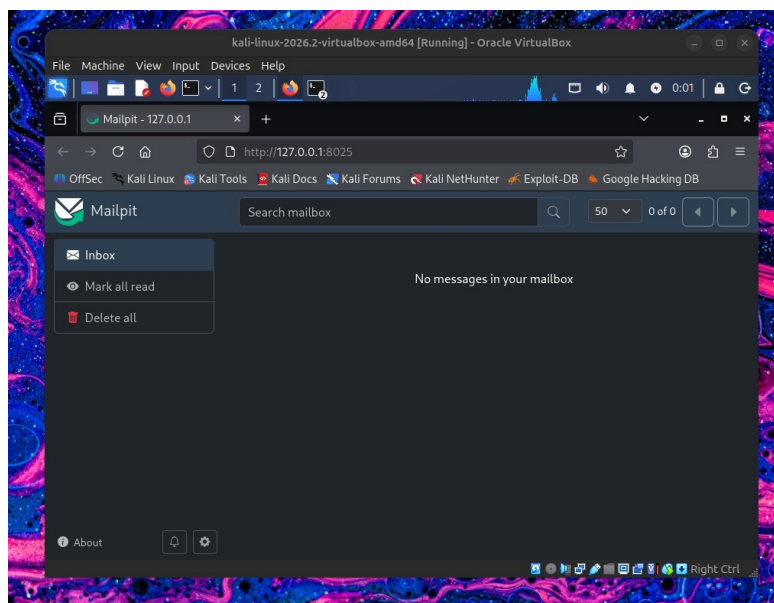


Figura 2. Bandeja de Mailpit disponible.

La interfaz web confirmó que el buzón de laboratorio estaba accesible sin necesidad de utilizar un servicio de correo externo.

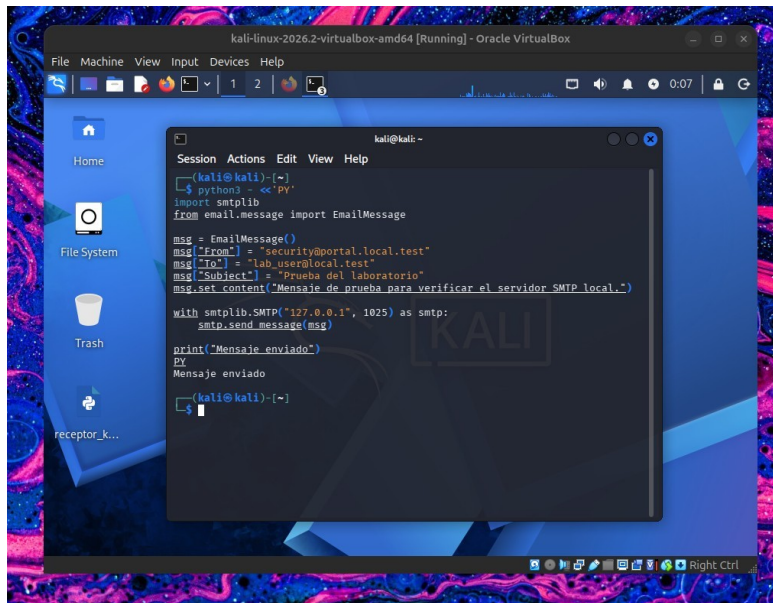


Figura 3. Prueba manual del servidor SMTP.

Se envió un mensaje de prueba mediante Python para verificar que Mailpit recibía correctamente mensajes en el puerto 1025.

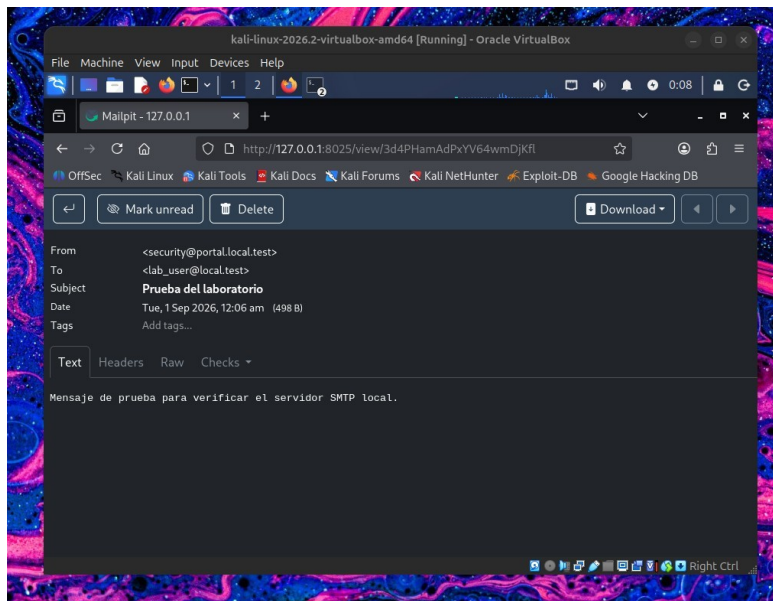


Figura 4. Mensaje de prueba recibido en Mailpit.

La recepción confirmó que el flujo SMTP local funcionaba antes de integrar SET.

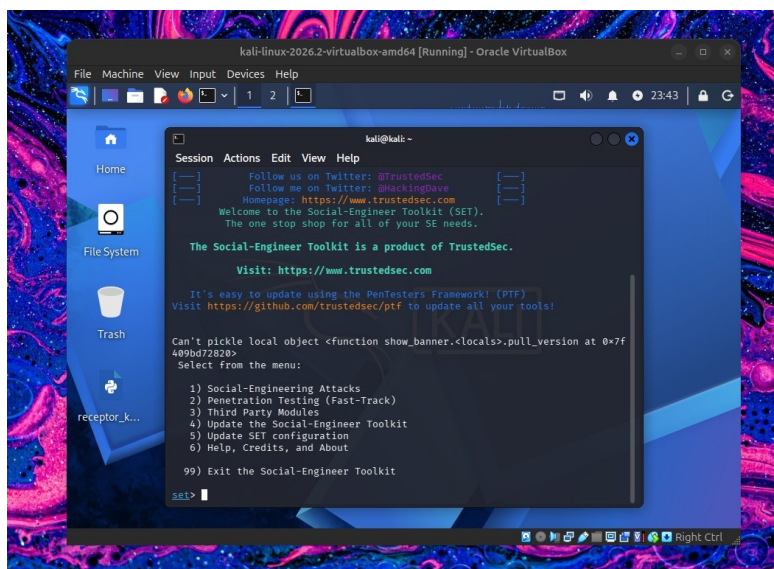


Figura 5. Inicio de Social-Engineer Toolkit.

SET se inició desde Kali Linux para preparar los vectores de ingeniería social solicitados en la actividad.

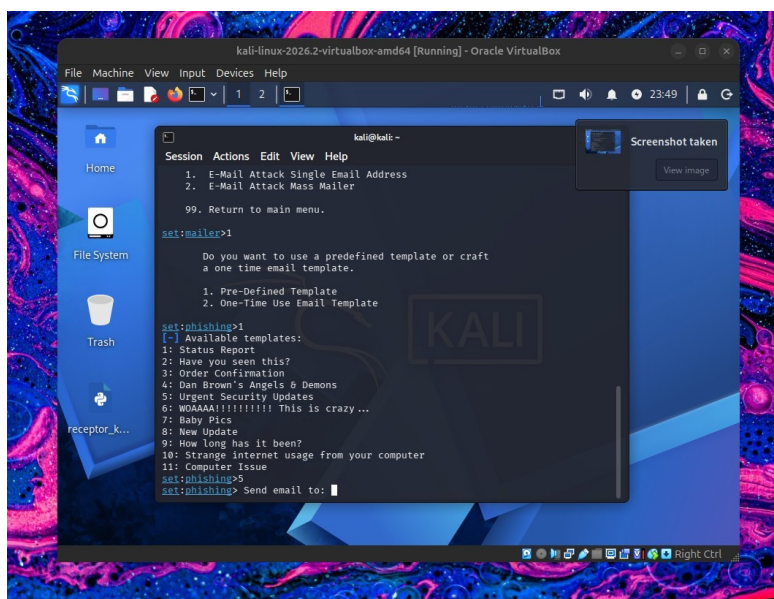


Figura 6. Selección de plantilla de correo.

Dentro del Mass Mailer se seleccionó una plantilla de actualización de seguridad para simular el componente de urgencia de una campaña de phishing.

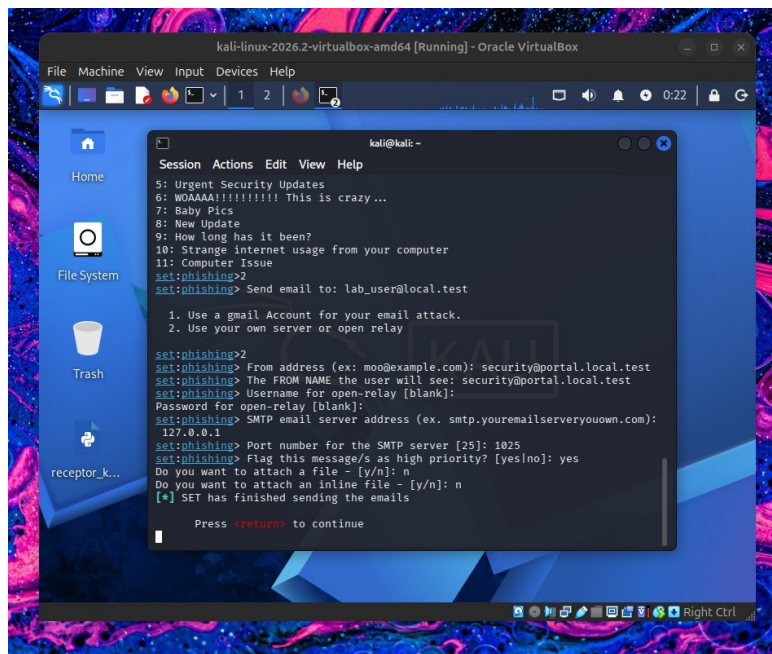


Figura 7. Configuración del envío SMTP en SET.

El mensaje se dirigió al buzón ficticio lab_user@local.test y se utilizó el servidor local 127.0.0.1:1025.

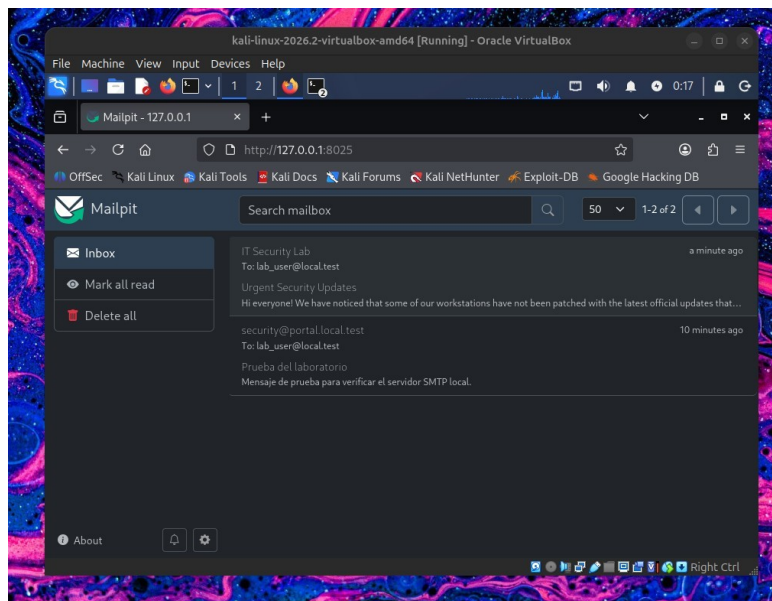


Figura 8. Correo de SET recibido en Mailpit.

Mailpit recibió el mensaje enviado por SET, demostrando que la simulación de correo permaneció dentro del laboratorio.

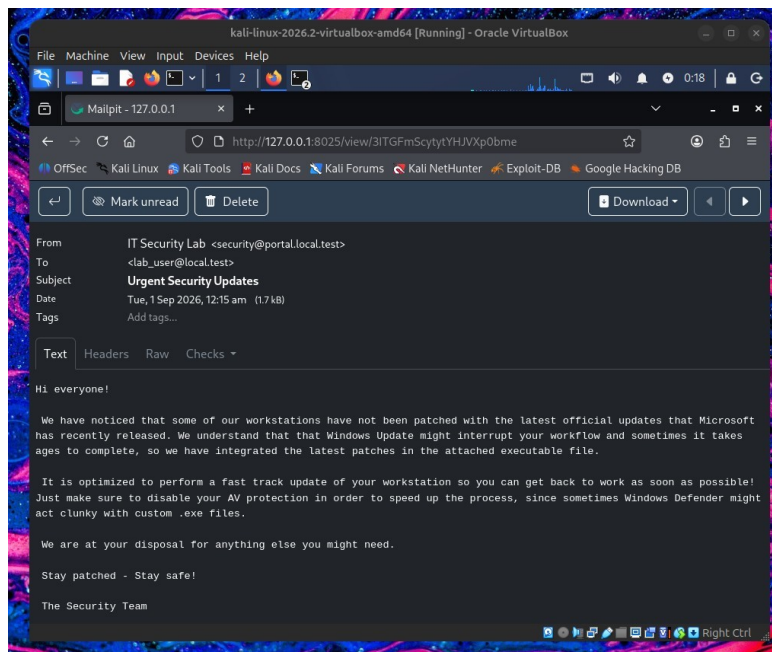


Figura 9. Contenido del mensaje de ingeniería social.

El contenido utiliza un tema de seguridad y urgencia para representar la presión psicológica común en mensajes de phishing.

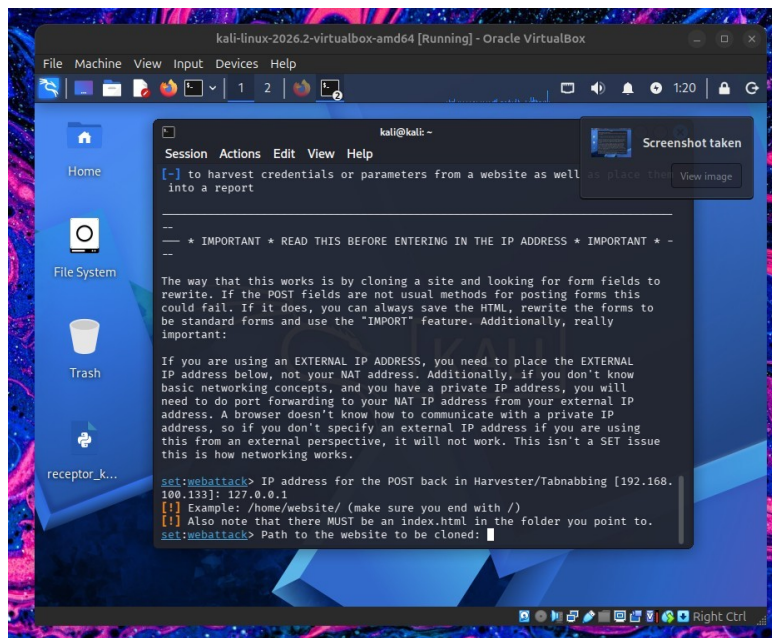


Figura 10. Selección de Credential Harvester.

Se accedió al vector Website Attack Vectors y al método Credential Harvester para estudiar la captura de parámetros enviados por un formulario.

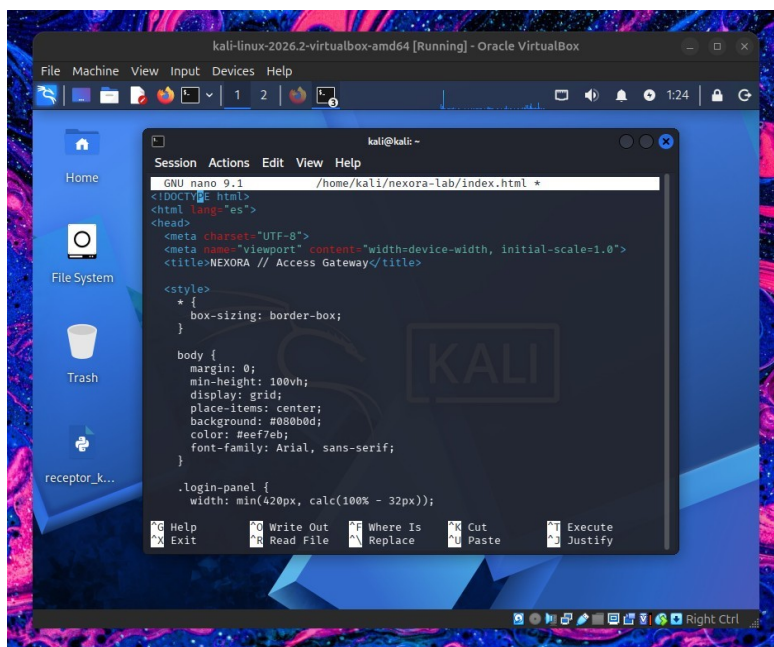


Figura 11. Construcción del portal ficticio NEXORA.

El sitio fue escrito específicamente para la práctica y no reproduce la identidad visual de una empresa o institución real.

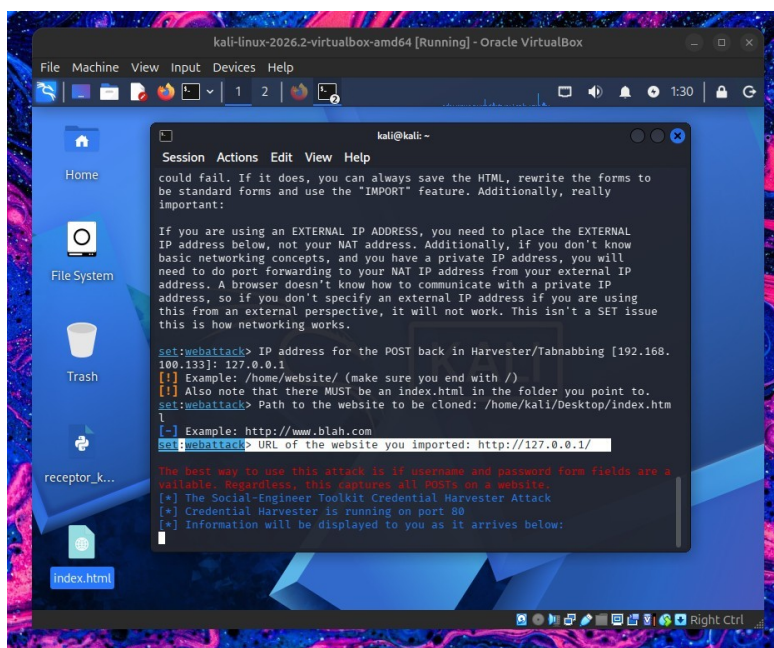


Figura 12. Credential Harvester activo en localhost.

SET quedó escuchando en el puerto 80 y preparado para registrar peticiones POST generadas por el formulario de laboratorio.

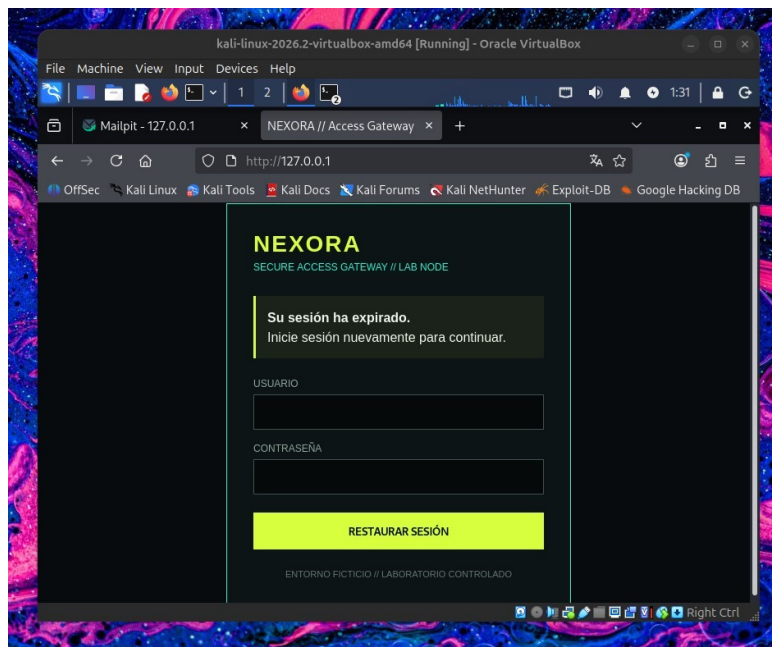


Figura 13. Portal NEXORA servido localmente.

El navegador accedió a `http://127.0.0.1/` y mostró el formulario ficticio con el mensaje de sesión expirada.

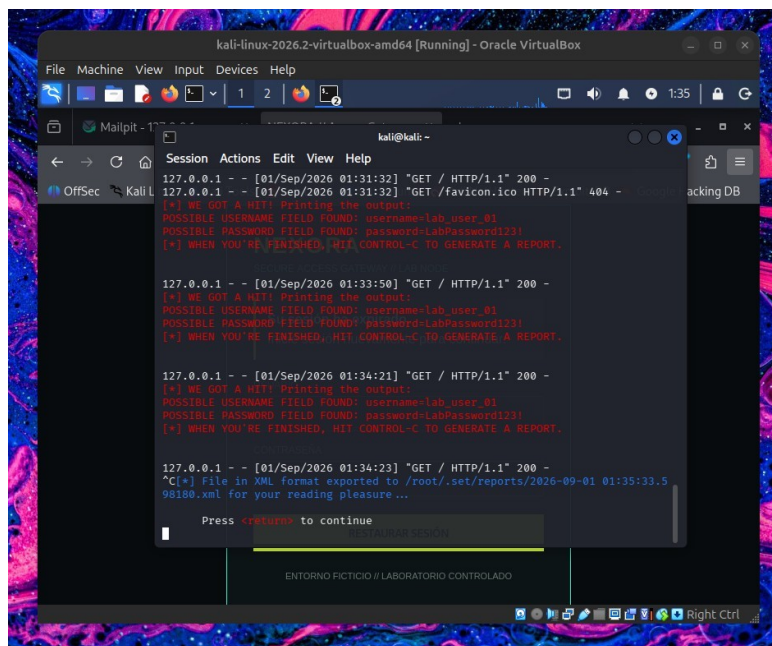


Figura 14. Captura de parámetros por SET.

Al enviar datos ficticios desde el formulario, SET registró la petición y mostró los parámetros recibidos. Esta evidencia demuestra captura de datos, no descifrado de una contraseña.

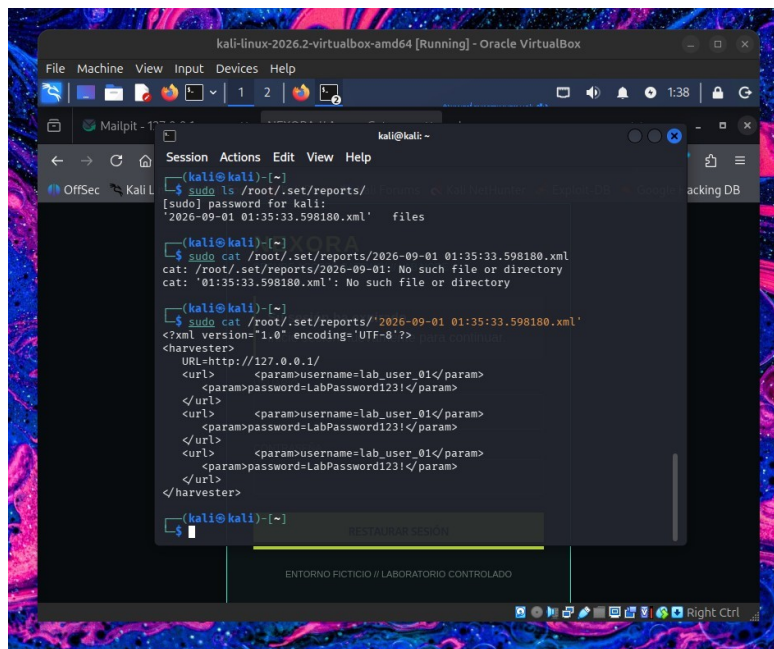


Figura 15. Registro persistente generado por SET.

El reporte XML almacenado por SET permitió comprobar que la información del ejercicio se conservó después de la interacción y podía revisarse posteriormente.

5. Explicación del flujo de captura de información

Un Credential Harvester es un componente que registra los valores enviados por un usuario a través de un formulario web. Dentro de una campaña de phishing, su función consiste en recibir y almacenar los parámetros que la víctima introduce en una página controlada por el atacante. La herramienta no necesita vulnerar criptográficamente la contraseña: obtiene el dato porque este fue entregado al formulario.

Flujo de captura de información en el laboratorio



Entorno aislado: localhost / datos de prueba / sin exposición a Internet

Figura 16. Flujo técnico de la simulación realizada.

5.1 Recorrido técnico

- El usuario de laboratorio abre el portal NEXORA servido en 127.0.0.1.
- Los campos del formulario contienen los nombres username y password.
- Al presionar el botón de ingreso, el navegador genera una petición HTTP POST hacia el servidor local.
- SET, ejecutando Credential Harvester en el puerto 80, recibe la petición y procesa sus parámetros.
- Los datos de prueba son mostrados por SET y posteriormente quedan almacenados en el reporte local.

La petición HTTP es el punto central del ejercicio. Los valores no fueron obtenidos mediante fuerza bruta, explotación de una vulnerabilidad ni cracking de hashes. El servidor recibió exactamente la información que el formulario transmitió. Por ello, "captura de credenciales" y "vulneración de una contraseña" representan procesos técnicos distintos.

5.2 Diferencia entre captura y vulneración

Captura de credenciales	Vulneración de contraseña
El usuario introduce el dato en un formulario y el servidor controlado registra el parámetro recibido.	Implica obtener o reconstruir una contraseña mediante técnicas como cracking, explotación o ataques sobre mecanismos de autenticación.

6. Indicadores de phishing

Indicador	Por qué es relevante
Dominio o URL no correspondiente	La dirección del portal no pertenece a la organización que supuestamente representa. Revisar el dominio antes de autenticarse es una señal crítica.
Urgencia injustificada	Mensajes como "su sesión ha expirado" o "actualización urgente" buscan reducir el tiempo que la persona dedica a verificar la legitimidad de la solicitud.
Solicitud inesperada de credenciales	Una petición de usuario y contraseña que no fue iniciada por el propio usuario debe considerarse sospechosa.
Inconsistencias visuales o de contexto	Logos, tipografías, textos, rutas o mensajes que no coinciden con el portal habitual pueden revelar una página fraudulenta.
Enlaces con destino inesperado	El texto visible de un enlace puede aparentar legitimidad mientras el destino real dirige a otra dirección; revisar el destino antes de abrirlo reduce el riesgo.

7. Controles de seguridad propuestos

Control	Alcance y limitación
Autenticación multifactor (MFA)	Reduce el impacto de una contraseña capturada porque el atacante todavía necesitaría un segundo factor. Limitación: ciertos esquemas de phishing avanzado pueden intentar engañar también respecto al segundo factor.
Capacitación y simulaciones	Ayudan a reconocer urgencia, dominios incorrectos y solicitudes inesperadas. Limitación: dependen de la atención y experiencia de cada usuario.
Filtros de correo y análisis de URLs	Bloquean mensajes sospechosos, dominios conocidos por abuso o enlaces maliciosos. Limitación: pueden existir falsos positivos y campañas nuevas que aún no estén clasificadas.
Gestores de contraseñas	El autocompletado ligado al dominio puede alertar cuando una página falsa no coincide con el sitio legítimo. Limitación: no protege si el usuario copia y pega manualmente sus credenciales.
Políticas de acceso y verificación del dominio	Favorecen el acceso mediante marcadores o portales conocidos y la revisión de HTTPS y dominio. Limitación: HTTPS por sí solo no demuestra que un sitio sea legítimo.

7.1 Alcance de los controles

La protección efectiva contra phishing requiere combinar controles técnicos y humanos. Ninguna medida individual elimina completamente el riesgo: MFA limita el uso de contraseñas robadas, los filtros reducen la exposición, los gestores de contraseñas ayudan a detectar dominios no coincidentes y la capacitación mejora la toma de decisiones. La defensa más sólida surge de la combinación de estas capas.

8. Conclusión

La actividad permitió reproducir de manera controlada el funcionamiento básico de una campaña de ingeniería social sin recurrir a servicios reales ni involucrar a terceros. La integración de SET con Mailpit mostró que el componente de correo puede simularse completamente en localhost, mientras que Credential Harvester permitió observar cómo los parámetros de un formulario viajan mediante una petición HTTP y son registrados por el servidor.

El principal aprendizaje fue identificar que una técnica de credential harvesting no necesita romper una contraseña. Su efectividad depende de convencer al usuario para que entregue voluntariamente información en una página que aparenta ser legítima. Esta diferencia ayuda a comprender por qué el phishing combina elementos técnicos con manipulación psicológica.

También se comprobó la importancia de revisar dominios, contexto, urgencia y solicitudes inesperadas de autenticación. A nivel defensivo, la combinación de MFA, capacitación, filtros de correo, gestores de contraseñas y políticas de acceso puede reducir tanto la probabilidad de éxito como el impacto de una campaña. Finalmente, el uso de un laboratorio aislado permitió analizar estos mecanismos de forma ética, reproducible y segura.

9. Referencias

- TrustedSec. (2026). Social-Engineer Toolkit (SET). Repositorio oficial: <https://github.com/trustedsec/social-engineer-toolkit>
- Mailpit. (2026). Documentation - SMTP server and configuration. <https://mailpit.axllent.org/docs/>
- Cybersecurity and Infrastructure Security Agency (CISA). Recognize and Report Phishing. <https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>
- López Contreras, S. (2026). Actividad 04 - Una página demasiado convincente. CNO IV - Seguridad Informática, UPSLP. Material de clase proporcionado para la práctica.